

C6 – Vérifier le respect des règles d'utilisation des ressources numériques

Charte informatique, RGPD et sensibilisation cybersécurité – Stage AP-HP

Date : 30/06/2025 au 12/08/2025 — Stage Hôpital Robert-Debré (AP-HP)

■ RGPD – Règlement Général sur la Protection des Données : <https://www.cnil.fr/fr/rgpd-de-quoi-parle-t-on>

■ ANSSI – Bonnes pratiques cyber : <https://www.ssi.gouv.fr/particulier/bonnes-pratiques/>

Présentation

Vérifier le respect des règles d'utilisation des ressources numériques implique de s'assurer que les utilisateurs et les systèmes respectent la politique de sécurité informatique de l'organisation. Cela inclut le contrôle des accès, la conformité au RGPD, et la sensibilisation des utilisateurs aux bonnes pratiques cybersécurité.

En stage à l'AP-HP, environnement critique où la confidentialité des données patients est primordiale, cette compétence a été mise en œuvre à travers des actions de sensibilisation, de contrôle des accès et d'audit des postes de travail.

Cadre réglementaire

Le RGPD dans un environnement hospitalier

- Les données de santé sont des données sensibles (article 9 du RGPD)
- Obligation de traçabilité des accès aux dossiers patients
- Droit à l'effacement et à la portabilité pour les patients
- Obligation de nommer un DPO (Délégué à la Protection des Données)
- En cas de violation, notification à la CNIL sous 72h

La charte informatique

Chaque établissement dispose d'une charte informatique signée par tous les utilisateurs. Elle définit :

- Les usages autorisés et interdits des ressources informatiques
- Les règles de gestion des mots de passe
- L'interdiction de contournement des outils de sécurité
- Les sanctions applicables en cas de non-respect

Actions menées en stage

1. Sensibilisation aux bonnes pratiques cybersécurité

Dans le cadre du stage à l'AP-HP, une session de sensibilisation a été réalisée auprès des équipes soignantes :

- Risques liés aux mots de passe faibles ou partagés
- Reconnaissance d'un mail de phishing
- Procédure à suivre en cas d'incident de sécurité (qui appeler, comment signaler)
- Interdiction de brancher des supports USB non approuvés
- Verrouillage systématique des sessions lors des absences

2. Vérification des droits d'accès

- Audit des membres des groupes AD sensibles (Domain Admins, Administrateurs locaux)
- Désactivation des comptes utilisateurs inactifs (départs du personnel)
- Vérification que les droits NTFS sur les partages respectent le principe du moindre privilège
- Revue des journaux de connexion (Event Viewer – Événements 4624, 4625)

```
# PowerShell – Lister les comptes inactifs depuis 90 jours
```

```
Search-ADAccount -AccountInactive -TimeSpan 90.00:00:00 -UsersOnly | Select Name, LastLogonDate
```

```
# Désactiver un compte
```

```
Disable-ADAccount -Identity 'ancien.utilisateur'
```

3. Contrôle des postes de travail

- Vérification que les antivirus sont à jour sur les postes
- Contrôle des mises à jour Windows (Windows Update)
- Vérification de l'absence de logiciels non autorisés (via inventaire GLPI)
- Audit des clés USB connectées récemment (EventLog DeviceSetupManager)

Outils utilisés

Outil	Usage
Active Directory (ADUC)	Gestion des comptes, désactivation des inactifs
Observateur d'événements	Audit des connexions et échecs d'authentification
GLPI	Inventaire logiciel et détection de logiciels non autorisés
Wazuh SIEM	Alertes sur les comportements suspects
GPO	Enforcement des règles de sécurité sur les postes

Résultat obtenu

Les actions menées à l'AP-HP ont permis d'identifier et de désactiver 12 comptes inactifs, de sensibiliser une trentaine d'agents aux risques cyber, et de corriger plusieurs configurations non conformes sur des postes de travail. La démarche a été documentée sous forme de rapport remis au responsable SI.

■ Outils : Active Directory, Wazuh, GLPI, Observateur d'événements Windows

■ CNIL – Données de santé : <https://www.cnil.fr/fr/les-donnees-de-sante>